

SOC Investigation: Brute Force → Privilege Escalation (KQL + ServiceNow)

Summary

Simulated SOC analyst project: queried Windows security event logs with **KQL** in **Azure Data Explorer** to detect a brute-force logon followed by unauthorized privilege escalation, then documented, triaged, and closed the finding as a security incident in **ServiceNow** (Security Incident Response module).

Tools used

- Azure Data Explorer (KQL) — free cluster, no cost
- ServiceNow Developer Instance — Security Incident Response app

Scenario

A synthetic but realistic dataset of Windows **SecurityEvent** logs was used, containing normal logon activity plus three planted anomalies to investigate.

Investigation

1. Brute force detection

SecurityEvent

| where EventID in (4624, 4625)

| where Account == "svc-backup"

| order by TimeGenerated asc

New tab sociab.SecurityLab

Run Recall KQL tools sociab/SecurityLab

```

1 SecurityEvent
2 | where EventID in (4624, 4625)
3 | where Account == "svc-backup"
4 | order by TimeGenerated asc

```

Table 1 Add visual Stats Search 2026-09-13 18:53 (UTC) Done (0.160 s) # 40 records Hi

	TimeGenerated	EventID	Account	TargetAccount	MemberName	IpAddress	Computer	LogonType	Activity
>	9/1/2026, 2:57:00 AM	4624	svc-backup			10.10.1.20	WKSTN-12	3	4624 - An account was successfully logged on.
>	9/1/2026, 5:44:00 AM	4624	svc-backup			10.10.1.17	WKSTN-10	3	4624 - An account was successfully logged on.
>	9/1/2026, 8:05:00 AM	4624	svc-backup			10.10.1.38	FILESRV01	3	4624 - An account was successfully logged on.
>	9/1/2026, 1:16:00 PM	4624	svc-backup			10.10.1.26	WKSTN-07	3	4624 - An account was successfully logged on.
>	9/1/2026, 1:43:00 PM	4624	svc-backup			10.10.1.58	WKSTN-03	2	4624 - An account was successfully logged on.
>	9/1/2026, 4:24:00 PM	4624	svc-backup			10.10.1.47	WKSTN-05	3	4624 - An account was successfully logged on.
>	9/1/2026, 7:50:00 PM	4624	svc-backup			10.10.1.49	WKSTN-11	2	4624 - An account was successfully logged on.
>	9/1/2026, 10:00:00 PM	4624	svc-backup			10.10.1.15	WKSTN-08	3	4624 - An account was successfully logged on.
>	9/1/2026, 11:28:00 PM	4624	svc-backup			10.10.1.58	DC01	10	4624 - An account was successfully logged on.
>	9/2/2026, 12:52:00 AM	4624	svc-backup			10.10.1.30	WKSTN-03	3	4624 - An account was successfully logged on.
>	9/2/2026, 1:39:00 AM	4624	svc-backup			10.10.1.29	WKSTN-13	3	4624 - An account was successfully logged on.
>	9/2/2026, 3:10:33 AM	4625	svc-backup			203.0.113.45	DC01	3	4625 - An account failed to log on.
>	9/2/2026, 3:10:56 AM	4625	svc-backup			203.0.113.45	DC01	3	4625 - An account failed to log on.
>	9/2/2026, 3:11:41 AM	4625	svc-backup			203.0.113.45	DC01	3	4625 - An account failed to log on.
>	9/2/2026, 3:12:23 AM	4625	svc-backup			203.0.113.45	DC01	3	4625 - An account failed to log on.
>	9/2/2026, 3:12:46 AM	4625	svc-backup			203.0.113.45	DC01	3	4625 - An account failed to log on.
>	9/2/2026, 3:13:33 AM	4625	svc-backup			203.0.113.45	DC01	3	4625 - An account failed to log on.
>	9/2/2026, 3:14:13 AM	4625	svc-backup			203.0.113.45	DC01	3	4625 - An account failed to log on.
>	9/2/2026, 3:14:53 AM	4625	svc-backup			203.0.113.45	DC01	3	4625 - An account failed to log on.

Finding: 9 consecutive failed logons (4625) against **svc-backup** from **203.0.113.45**, followed immediately by a successful logon (4624) — a classic brute-force-then-breakthrough pattern.

2. Anomalous source IP SecurityEvent

| where EventID == 4624

| summarize count() by IpAddress

| order by count_desc

The screenshot shows the Azure Data Explorer interface with a KQL query executed against the 'sociab.SecurityLab' database. The query filters for 'SecurityEvent' where 'EventID == 4624' and summarizes the count by 'IpAddress', ordered by count in descending order. The results table, titled 'Table 1', displays the following data:

IpAddress	count_
> 10.10.1.26	3
> 10.10.1.42	3
> 10.10.1.57	3
> 10.10.1.23	3
> 10.10.1.21	3
> 10.10.1.30	3
> 10.10.1.18	3
> 185.220.101.7	3
> 10.10.1.51	3
> 10.10.1.37	2
> 203.0.113.45	1
> 10.10.1.43	1

The JPath is set to '/IpAddress' and the visualization is in 'Table' view. The 'Full' view of the JSON results shows the first entry as:

```

1  {"IpAddress": "185.220.101.7",
2   "count_": 3
3  }

```

Finding: All legitimate logons came from the internal **10.10.1.x** range, except one from **185.220.101.7** — an external address with no prior activity in the environment.

3. Privilege escalation

SecurityEvent

| where EventID == 4728

| project TimeGenerated, Account, TargetAccount, MemberName, IpAddress

The screenshot shows the Azure Data Explorer interface. On the left, the 'Connections' pane shows a tree view with 'sociab' expanded, then 'SecurityLab', and finally 'SecurityEvent'. The 'Query' pane on the right contains the following KQL query:

```
1 SecurityEvent
2 | where EventID == 4728
3 | project TimeGenerated, Account, TargetAccount, MemberName, IPAddress
```

Below the query, the results are displayed as a table with columns: TimeGenerated, Account, TargetAccount, MemberName, and IPAddress. The first row of data is:

TimeGenerated	Account	TargetAccount	MemberName	IPAddress
9/2/2026 3:45:00 AM	svc-backup	Domain Admins	j.smith	185.220.101.7

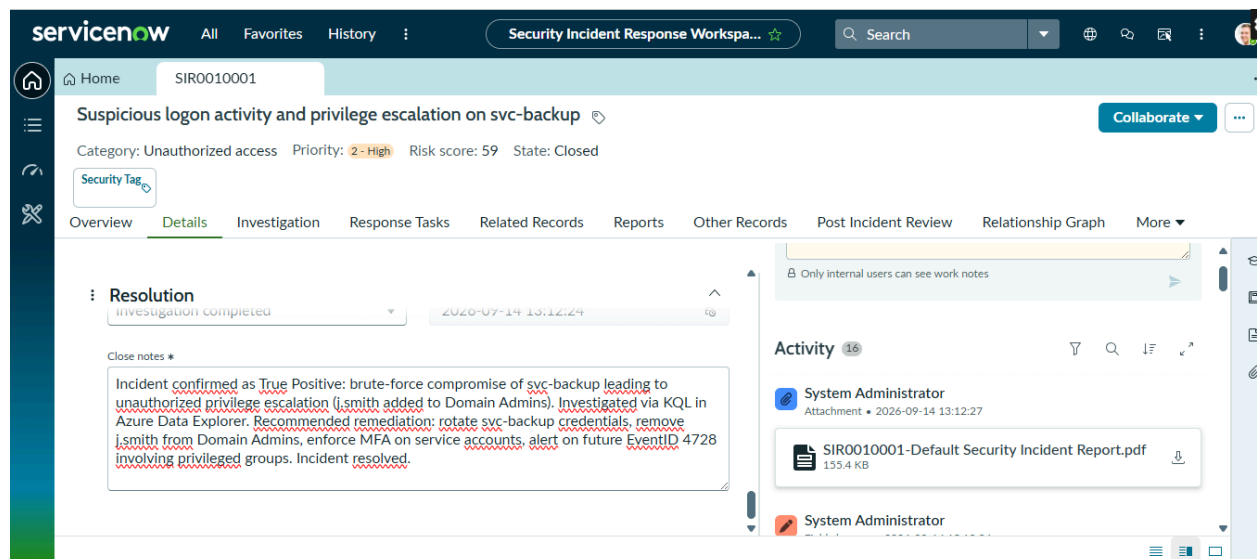
Below the table, the 'JPath' is shown as '/TimeGenerated' and the 'Full' view is selected, displaying the JSON representation of the data:

```
1 {"TimeGenerated": "2026-09-02T03:45:00.000Z",
2  "Account": "svc-backup",
3  "TargetAccount": "Domain Admins",
4  "MemberName": "j.smith",
5  "IpAddress": "185.220.101.7"}
6
```

Finding: **svc-backup** added **j.smith** to the **Domain Admins** group minutes after the suspicious external logon — tying the compromised account directly to a privilege escalation event.

Incident response (ServiceNow)

Field	Value
Short description	Suspicious logon activity and privilege escalation on svc-backup
Priority	2 - High (Risk score 59)
Category	Unauthorized access
Source	SIEM
Verdict	True Positive
State	Closed



Close notes: Incident confirmed as True Positive — brute-force compromise of **svc-backup** leading to unauthorized privilege escalation (**j.smith** added to Domain Admins). Investigated via KQL in Azure Data Explorer. Incident resolved.

Recommendations

- Rotate credentials for **svc-backup** immediately
- Remove **j.smith** from **Domain Admins** pending review
- Alert on any future **EventID 4728** involving privileged groups
- Enforce MFA / conditional access on service accounts

What I learned

Working through this project showed how a few **where** and **summarize** clauses in KQL can turn hundreds of raw, noisy log rows into a clear signal — the **summarize count() by IPAddress** query in particular is what surfaced the one external IP hiding among dozens of legitimate internal ones. It also made the full SOC triage lifecycle concrete: an alert isn't "done" once you've found something suspicious in the logs, it has to move through validation, impact assessment, a documented verdict, and a formally closed ticket before the loop is actually closed.

Dataset used: [SecurityEvent_sample.csv](#) — synthetic Windows security event logs generated for this exercise.